# Phase 14 — Headless AI-VAPT Benchmark Report

**Target:** http://127.0.0.1:3000/ (OWASP Juice Shop v20.3.0) • **Strix Version:** 1.7.0 • **Date:** 2026-11-06

## 1. AI Model Inference & Reliability Benchmark

| Model | Served ID | TTFT | Tokens/s | Tool Success | Stability | Verdict |
|---|---|---|---|---|---|---|
| Qwen3-Coder-30B | kaggle-model | 1.56s | 40.16 | 100.0% | 100% Uptime | RECOMMENDED |
| Qwen2.5-1.5B | qwen2.5:1.5b | 1.37s | 49.65 | 100.0% | Offline Safe | TRIAGE ONLY |
| OpenRouter Hub | openrouter/auto | N/A | N/A | 0.0% | Quota Exhausted | NOT RECOMMENDED |

## 2. Execution Engine & Scan Depth Matrix Highlights

| ID | Model | Engine | Depth | Status | Turns | Attempts | Findings | GAP-1 Tested |
|---|---|---|---|---|---|---|---|---|
| M01 | kaggle-model | Autonomous | Quick | Failed | 15 | 15 | 1 | 3 / 6 (Incomplete) |
| M03 | kaggle-model | Autonomous | Deep | Completed | 500 | 36 | 0 | 8 / 8 (100%) |
| M04 | kaggle-model | Fast Web | Quick | Completed | 50 | 14 | 2 | 6 / 6 (100%) |
| M07 | kaggle-model | Simulation | Quick | Completed | 50 | 33 | 2 | 16 / 16 (13 Pivots) |
| M13 | qwen2.5:1.5b | Fast Web | Quick | Completed | 50 | 14 | 2 | 6 / 6 (100%) |

## 3. Independent Hermes Ground Truth Correlation

| ID | Finding | Severity | Hermes | Strix Autonomous Deep | Root Cause Analysis |
|---|---|---|---|---|---|
| F-01 | Unprivileged User Enumeration | High | CONFIRMED | RULED_OUT_UNAUTH | Hermes used customer token; Strix unauthenticated. |
| F-02 | Password in JWT Payload | High | CONFIRMED | RULED_OUT_UNAUTH | Hermes decoded JWT; Strix evaluates HTTP transport headers |
| F-03 | Public User Data Exposure | Medium | CONFIRMED | EXPLORED_NO_ISSUE | Classified as public API schema rather than secret leak. |
| F-04 | Object-Level IDOR | Medium | CONFIRMED | RULED_OUT_UNAUTH | Precondition requires active customer session token. |
| F-05 | Weak Security Headers | Low | CONFIRMED | RULED_OUT / OBS | Guard 3 prevents synthetic critical CVSS without DOM PoC. |
| F-06 | Default Admin Password | High | CONFIRMED | NOT_TESTED | Strix default safety policy excludes brute force. |
| F-07 | Information Leak via 500 | Low | CONFIRMED | RULED_OUT | Active scanner classifies 500 as non-exploitable error. |

## 4. Recommended Production Configuration

**Model:** Qwen3-Coder-30B-A3B-Instruct-Q4_K_M (Cloud Hosted via llama.cpp) • **Engine:** Full Autonomous Pentest (Docker sandbox multi-agent core) • **Scan Depth:** Deep Autonomous • **Turn Budget:** 500 Turns • **GAP-2 Threshold:** k = 2 • **Auth Context:** When assessing authenticated endpoints (e.g., F-01, F-04), configure target credentials in scan profile.